10.L Autentificación Linux en red

- La herramientas **authselect** sirve para configurar los mecanismos de autentificación permitidos en Linux. Las opciones son, entre otras:
  - NIS (en red)
  - Kerberos (en red)
  - LDAP (en red)
  - Shadow Passwords (local, opción por defecto)
  - SMB (en red)
  - Winbind (en red)
- Authselect modifica ficheros en tres localizaciones:
  - /etc/nnswitch.conf
  - /etc/pam.d/*
  - /etc/dconf/db/distro.d/*

10.L Autentificación Linux en red

- El archivo **/etc/nssswitch.conf** (Name Service Switch, NSS) se usa por varias aplicaciones para determinar las fuentes desde las que se obtienen los servicios de nombres y en qué orden
- **Linux-PAM** (Pluggable Authentication Modules) es un sistema de módulos que manejan las tareas de autentificación de aplicaciones o servicios en el sistema. Esta configuración es dinámica y depende de los ficheros de configuración en /etc/pam.d
- **authselect** se emplea para elegir un perfil de autentificación para un host, y este perfil se aplicará a cada usuario que inicie sesión en el host. Los perfiles que estám por defecto son **sssd** (System Security Services Daemon, se conecta a un dominio mediante Kerneros), y **winbind** (un daemon de Samba con funciones de autentificación). También se incluye el perfil **nis** (por compatibilidad con redes existentes – se estudia más adelante)
- authselect permite modificar los perfiles para añadir opciones para usar huellas digitales o tarjetas inteligentes

10.L Autentificación Linux en red

```
# group:     db files

passwd:      sss files systemd
shadow:     files sss
group:       sss files systemd

hosts:      files dns myhostname

bootparams: files

ethers:     files
netmasks:   files
networks:   files
protocols:  files
rpc:        files
services:   files sss

netgroup:   sss

publickey:  files

automount:  files sss
aliases:    files
[lucianosanchez@localhost ~]$
```

- Contenido del archivo nsswitch.conf, mostrando por ejemplo que las contraseñas de usuario (passwd) pueden comprobarse conectándose un dominio (mediante sssd), mediante archivos locales (files) o a través de systemd (nss-systemd)

10.L NIS -Network Information Service

- NIS es una de las formas en que un cliente Linux puede autentificarse ante un servidor remoto. Este servicio consiste en compartir varias bases de datos en el equipo servidor. Estas bases de datos contienen la información que localmente estaría almacenada en /etc/passwd, /etc/shadow y /etc/group, es decir:
  - nombres de usuario, passwords, directorios HOME
  - información de grupo

10.L NIS

- En cada red debe haber al menos una máquina actuando de servidor NIS. Pueden tenerse múltiples servidores, cada uno de los cuales sirve a un cierto dominio, o bien cooperar entre sí, de forma que uno de los servidores sea el maestro y otros los esclavos
- Los servidores esclavos almacenan copias de las bases de datos NIS desde el servidor maestro, y se actualizan cada vez que hay cambios. Cuando uno de los servidores cae, el cliente tratará de encontrar otro servidor.
- Las bases de datos NIS están en formato DBM, derivado de bases de datos ASCII. Hay herramientas que convierten a DBM ficheros de texto como /etc/passwd y /etc/group
- Los servidores esclavos son notificados de los cambios via el programa yppush, y se mantienen sincronizados. Los clientes no necesitan este sincronismo, ya que acceden directamente al servidor o leen la información almacenada en una de las bases en DBM

10.L Instalación de un servidor NIS

- portmap tiene que estar en ejecución, y se tiene que permitir la autentificación con NIS con **system-config-authentication** o con **authselect (authselect select nis –force)**
- SELinux debe conocer que usamos NIS: **setsebool –P nis_enabled on**
- **Se configuran el servidor y los clientes NIS (ver transparencia siguiente)**
- Se activan los servicios necesarios: **systemctl enable - -now rpcbind ypbind nis-domainname oddjobd**
- Si se sale y se entra en sesión, NIS está activo (puede comprobarse con la orden ypwhich, que muestra el servidor a cargo del dominio)

10.L Configuración de un servidor NIS

1. Se activa el nombre del dominio: *nisdomainname nombreNIS*
2. En /etc/sysconfig/network se añade la línea *NISDOMAIN="nombreNIS"*
3. En el fichero de configuración /etc/yp.conf se añaden las líneas

   domain nombreNIS server nombreservidor

   ypserver nombreservidor
4. Se lanzan los demonios *ypserv* y *rpc.yppasswd*
5. Se entra en el directorio /var/yp y se ejecuta la orden make para crear la base de datos que NIS gestiona
6. Se lanza el demonio *ypbind*

10.L Instalación de un cliente NIS

- portmap tiene que estar en ejecución, y se ha tenido que permitir la autorización con system-config-authentication

1. Se ejecuta *nisdomainname nombreNIS*
2. En /etc/sysconfig/network se añade la línea *NISDOMAIN="nombreNIS"*
3. En el fichero de configuración /etc/yp.conf se añade la línea

   domain nombreNIS server nombreServidor

4. Se lanza *ypbind*
5. En /etc/passwd se añade la línea **+:*:0:0:::** (no necesario en versiones modernas)
6. En /etc/group se añade la línea **+:*:0:** (no necesario en versiones modernas)
7. Tiene que existir el directorio */var/yp*

10.L Seguridad NIS

- En */var/yp/securenets* se indican las redes o equipos que tienen acceso permitido al dominio NIS
  - Formato: *netmask network* o bien *host IP*:

    255.255.255.0 192.168.6.0

    host 192.168.6.5
- el comando *yppasswd* permite cambiar la contraseña en el servidor, si en éste está corriendo el demonio *rpc.yppasswd*
- Otros comandos permiten cambiar el shell (*ypchsh*), parámetros del usuario (*ypchfn*), o ver el contenido de los ficheros de passwords (*ypcat passwd*) y servidores (*ypcat ypservers*).

10.L Kerberos

- Kerberos es un protocolo de autentificación que permite usar redes inseguras.
- Es el protocolo empleado en las redes Windows
- Un cliente Linux puede conectarse a un proveedor de autentificación Windows en redes mixtas mediante SSSD

10. Kerberos: términos

- **Authentication Service (AS)** - Realiza la autentificación y es parte del Key Distribution Center (KDS).
- **Key Distribution Center (KDC) -** Mantiene las claves secretas para los "principals" (ver a continuación). Proporciona autentificación, crea y distribuye las claves de sesión. Utiliza criptografía simétrica. Un KDC tiene un Ticket Granting Service (TGS) y un Authentication Service.
- **Principal -** Cualquier objeto (usuario, aplicación, servicio o recurso) que utiliza Kerberos. Un KDC es responsable de un “reino” (realm). Cualquier principal confía en el KDC, pero los principales no confían uno en el otro. Sólo el KDC tiene una copia de la clave secreta de cada principal.
- **Reino (Realm) -** Conjunto de principales bajo responsabilidad de un KDC.
- **TGS (Ticket Granting Service) -** Parte del KDC que crea y distribuye tickets conteniendo claves de sesión a los principales
- **Ticket -** Fichas de autentificación digital enviadas desde el AS. El primer ticket enviado desde el AS a un principal se llama Ticket Granting Ticket (TGT).
- **Claves secretas y claves de sesión:** Claves de criptografía simétricas usadas para autentificación y encriptación.

10. Kerberos: Autentificación

- Con Kerberos, los usuarios tienen que demostrar su identidad ante cada aplicación, recurso o servicio antes de que puedan ser usados. El usuario hace login una única vez. Las fases de la autentificación son:

  1. Un usuario inicia sesión: se envía la información de la autentificación al AS (Authentication Service) del KDC (Key Distribution Center)

  2. El AS devuelve un ticket (encriptado) al computador del usuario.

  3. El ticket se desencripta con la password del usuario. El usuario se autentifica ante la red si la contraseña es correcta

10. Kerberos: Usuario accede a recurso

1. El computador del usuario envía un ticket inicial al Ticket Granting Service (TGS) del Key Distributrion Center (KDC).

2. TGS crea un nuevo ticket: Información de autentificación del usuario, más dos instancias de la misma clave de sesión. Este ticket vuelve al computador del usuario. Una instancia de la clave de sesión se encripta con la clave secreta del usuario. La otra instancia de la clave de sesión se encripta con la clave secreta del recurso deseado.

3. El software del computador del usuario (Kerberos) desencripta y extrae una instancia de la clave de sesión, inserta información de autentificación en el ticket y envía el ticket al recurso deseado. El recurso desencripta la segunda instancia de la clave de sesión con su propia clave secreta y recupera la información de autentificación del usuario.

10. Kerberos: Usuario accede a recurso (2)

- El recurso sabe que el ticket procede del KDC porque el ticket que ha recibido contiene una copia de la clave secreta del recurso y esa clave sólo es conocida por el KDC.

- El recurso confía en el ticket recibido porque contiene la clave secreta encriptada.

- El recurso compara también la información de usuario en el ticket con la información insertada por el usuario para asegurarse de que la identidad del usuario no ha sido suplantada.

10. Autentificación Kerberos

Cliente

Username: EllOviedo
Password: mipass

one way hash

Clave secreta del cliente

Authentication Server

Ticket Granting Server

Key Distribution Center

Servidor de archivos

2. AS comprueba si EllOviedo
está en la base de datos

AS

3. AS genera una clave
secreta para EllOviedo

TGS

Cliente

1. EllOviedo quiere acceder
al servidor de archivos

Servidor de Archivos

Cliente

1. Clave Sesión Cliente/TGS
(encriptada con la clave
secreta del cliente)

AS

2. Ticket Granting Ticket: incluye
Client ID
Client network address
Ticket validity period
clave de sesión Client/TGS
(encriptado con la
clave secreta TGS)

TGS

Servidor de Archivos

Cliente

AS

TGS

Cliente decodifica
mensaje I y obtiene
clave de Sesión Cliente/TGS
Cliente no puede decodificar
mensaje 2
(no tiene la clave secreta TGS)

Servidor de Archivos

Cliente

AS

3. Devuelve Ticket Granting Ticket
a partir del mensaje 2
(estaba encriptado con la clave secreta TGS) +
ID del servicio de archivos

TGS

4. Autentificador compuesto de
Client ID
Timestamp
(encriptado con la clave
Client/TGS del mensaje 1)

Servidor de Archivos

Cliente

TGS decodifica el mensaje 3
y obtiene el granting Ticket
(incluye Client ID,
Client Network address,
ticket validity period,
clave de sesión Client/TGS)

Ahora el cliente y el TGS
pueden hablar porque ambos
tienen la clave de sesión
Client/TGS

AS

TGS

Servidor de Archivos

Cliente

TGS decodifica el mensaje 4
usando la clave de sesión
Client/TGS
y obtiene
Client ID +
Timestamp
(con esto conoce cuándo
el cliente envió la solicitud)

TGS comprueba que Client ID
del mensaje 3 coincide con
Client ID de mensaje 4 y que
timestamp no excede el
periodo de validez del ticket

AS

TGS

Servidor de Archivos

5. Cliente-a-FS ticket:
Client ID
Network address
Validity Period
clave de sesión Cliente/Servidor
(Encriptado con la clave
secreta del
Servidor de Archivos,
sólo el FS puede decodificarlo)

AS

Cliente

TGS

6. Clave de sesión Cliente/Servidor
(encriptada con la clave de sesión
Cliente/TGS del mensaje 1)

Servidor de Archivos

Cliente

AS

TGS

Decodifica mensaje 6
usando la clave de sesión Cliente/TGS
y obtiene la clave de sesión
Cliente/Servidor

Servidor de Archivos

AS

5. Cliente-a-FS ticket:
Client ID
Network address
Validity Period
clave de sesión Cliente/Servidor
(Encriptado con la clave
secreta del
Servidor de Archivos)

TGS

7. Autentificador, compuesto de
Client ID
Timestamp
(encriptado con la clave Cliente/Servidor
de 6)

Cliente

Servidor de Archivos

Servidor de Archivos desencripta (5) usando
la clave secreta del servidor de archivos
y obtiene
Client ID
Network Address
Validity Period
Clave de Sesión Cliente/Servidor

AS

TGS

Servidor de Archivos desencripta (7)
usando la clave Cliente/Servidor
y obtiene
Client ID
Timestamp

Servidor de Archivos

Cliente

Servidor de Archivos comprueba que
Client ID de (5) = Client ID de (7)
y ticket no expiró (timestamp)

Servidor de Archivos envía al cliente un mensaje para comprobar su identidad y mostrar que puede realizar la petición

AS

TGS

8: Timestamp (en 7) + 1 encriptada con la clave de sesión Cliente/Servidor

Cliente desencripta 8 y comprueba que timespamp + 1 es correcto, con lo que el cliente confía en el servidor de archivos

Cliente

Servidor de Archivos

AS

TGS

Cliente

Cliente solicita un servicio

Servidor lo cumple

Servidor de Archivos